

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 4:	Pentest em Aplicações Web
Atividade 2:	File Upload
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Pentest em Aplicações Web*, para a qual utilizamos a sala do PortSwigger - <https://portswigger.net/>

No contexto destas salas, nosso foco é:

- 1) Laboratório 1 do Portswigger – Explorar uma vulnerabilidade de upload de imagem, não há validação dos arquivos antes de armazená-los no servidor, teremos que carregar um shell web php para extrair o conteúdo do arquivo `/home/carlos/secret`, a vulnerabilidade de upload imagem acontece quando não há a validação dos arquivos que vão para o servidor do site, o impacto é que qualquer tipo de arquivo pode ser carregado em nosso servidor, o atacante pode fazer upload de qualquer arquivo com o script malicioso, comandos, ataque DOS, fazendo com que tenha o controle do seu site e tenha acesso as informações mais sigilosas;
- 2) Laboratório 2 do Portswigger – Neste laboratório ele tenta impedir que se carregue arquivos inadequados diferente do primeiro laboratório, mas depende da verificação de entrada que podemos controlar, teremos que carregar um shell web php para extrair o conteúdo do arquivo `/home/carlos/secret`, mesmo o site não aceitando o arquivo podemos modificar o tipo de arquivo e fazer o upload podendo dar acesso a sua aplicação, através do Burp podemos modificar o tipo de arquivo e contornar a proibição do upload direto do arquivo através do site;
- 3) Laboratório 3 do Portswigger – Alguns tipos de arquivos são colocados na lista negra, mas podemos contornar esta defesa através de uma falha, teremos que carregar um shell web php para extrair o conteúdo do arquivo `/home/carlos/secret`, a vulnerabilidade é conseguir contornar uma lista negra através do servidor apache, ela ocorre quando tentamos fazer um upload de arquivo proibido e o site nos mostra o tipo de servidor e a versão que ele tem, fazendo isso o atacante pode pesquisar as vulnerabilidades da aplicação e testar no seu site deixando totalmente vulnerável;
- 4) Laboratório 4 do Portswigger. – Novamente utilizamos a lista negra, só que desta vez vamos utilizar uma técnica de ofuscação para contornar esta defesa, teremos que carregar um shell web php para extrair o conteúdo do arquivo `/home/carlos/secret`, a vulnerabilidade utiliza alguns códigos para ofuscar o upload de arquivo e carregar no servidor, ela ocorre quando a lista negra

permite alguns caracteres como %00 e arquivos como arquivo.php.jpg utilizando outra extensão para não ser detectada, o impacto pode resultar em um vazamento de dados, com isso o atacante utilizando os caracteres pode ter acesso ao seu site e suas informações.

A sala do Portswigger é composta por quatro atividades:

- 1) Execução remota de código via upload de shell da web - <https://portswigger.net/web-security/file-upload/lab-file-upload-remote-code-execution-via-web-shell-upload>
- 2) Upload do shell da Web por meio de bypass de restrição de tipo de conteúdo - <https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-content-type-restriction-bypass>
- 3) Upload de shell da Web por meio de desvio de lista negra de extensão - <https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-extension-blacklist-bypass>
- 4) Upload do shell da Web por meio de extensão de arquivo ofuscada - <https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-obfuscated-file-extension>

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

- 1) Acessar os sites informados acima.
- 2) Utilizar a VM do Kali Linux: Para utilizar o Burp e executar alguns comandos no terminal.

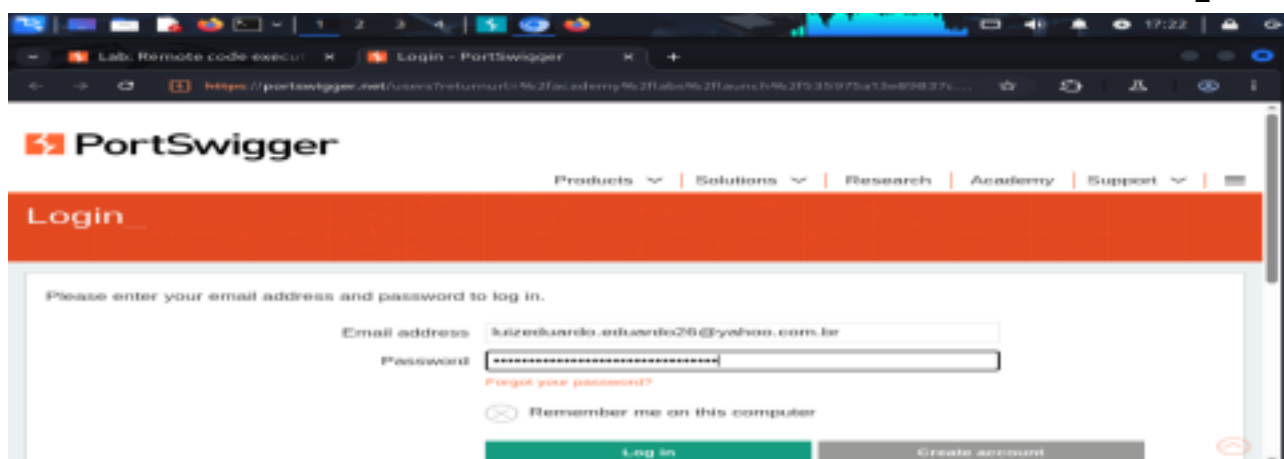
2.2. Atividade prática

O objetivo desta atividade é realizar as 4 tarefas propostas no PortSwigger

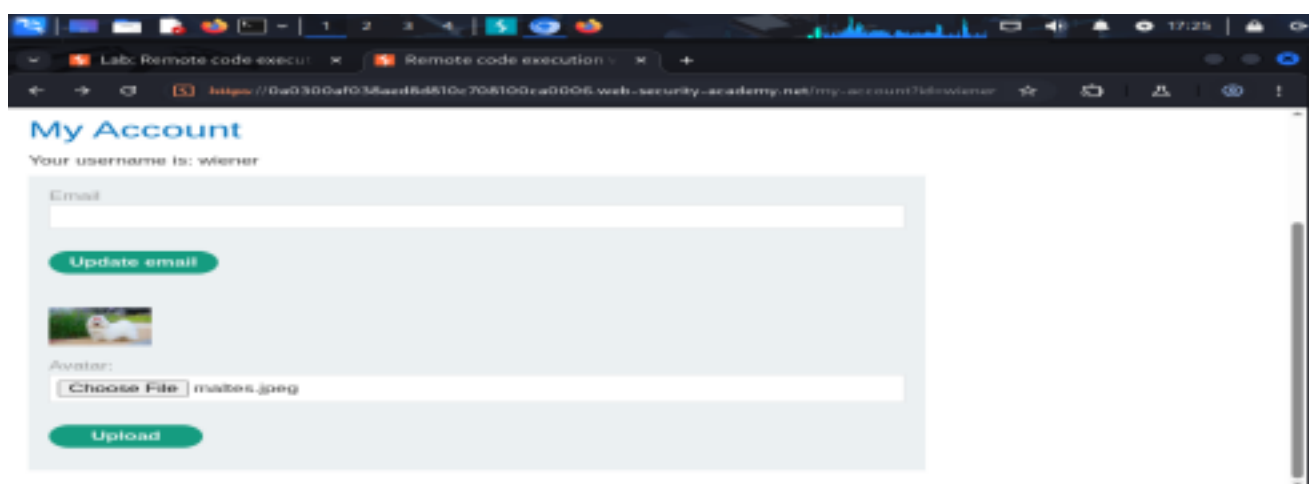
Atividade 1 - Execução remota de código via upload de shell da web

Passo 1 – Entre com seu login e senha no PortSwigger no site:

<https://portswigger.net/web-security/file-upload/lab-file-upload-remote-code-execution-via-web-shell-upload> e clique em acesse o laboratório

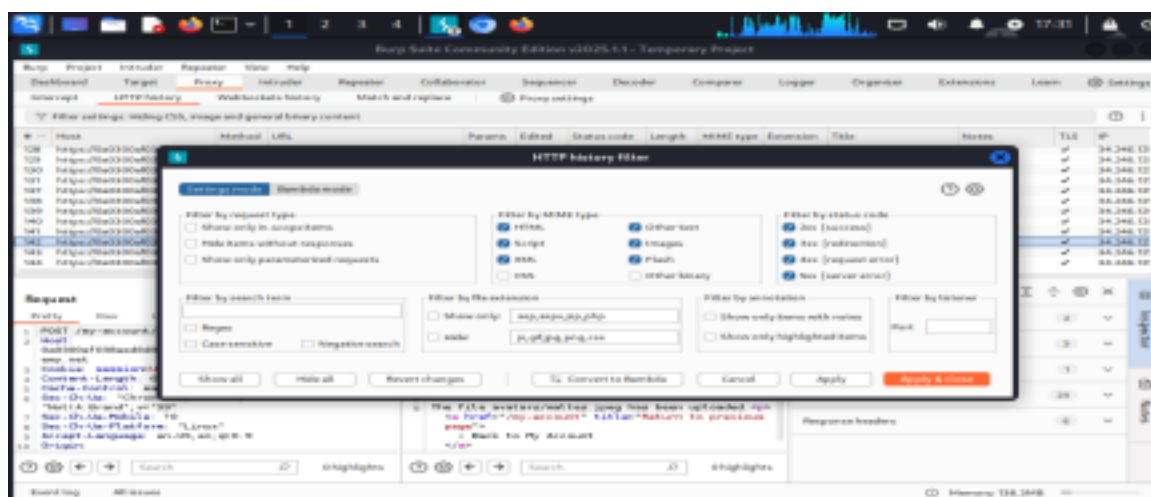


Passo 2 – Em My account digite o usuário wiener e a senha peter, depois clique em Choose File, faça o upload do arquivo em jpg no caso maltes.jpg, informará que o arquivo foi carregado e clique em Back My Account.

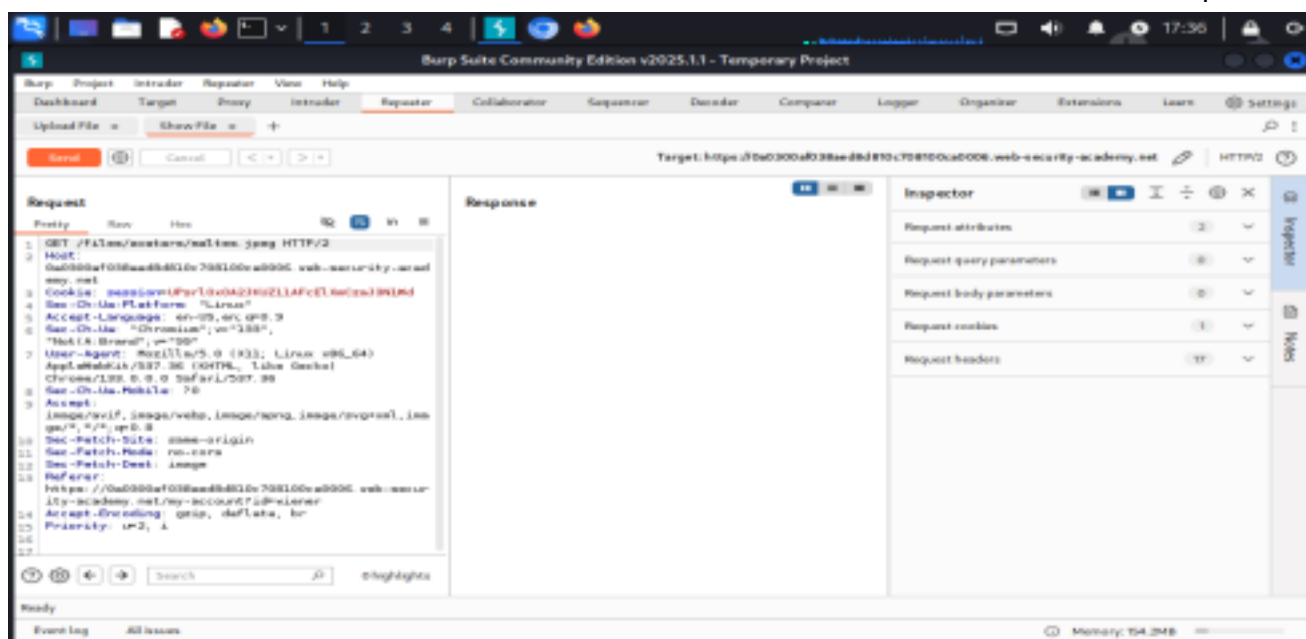


Passo 3 – Vamos no Burp em Proxy e HTTP History para localizar o arquivo POST my-account/avatar clicar com o botão direito e escolher Send to Repeater.

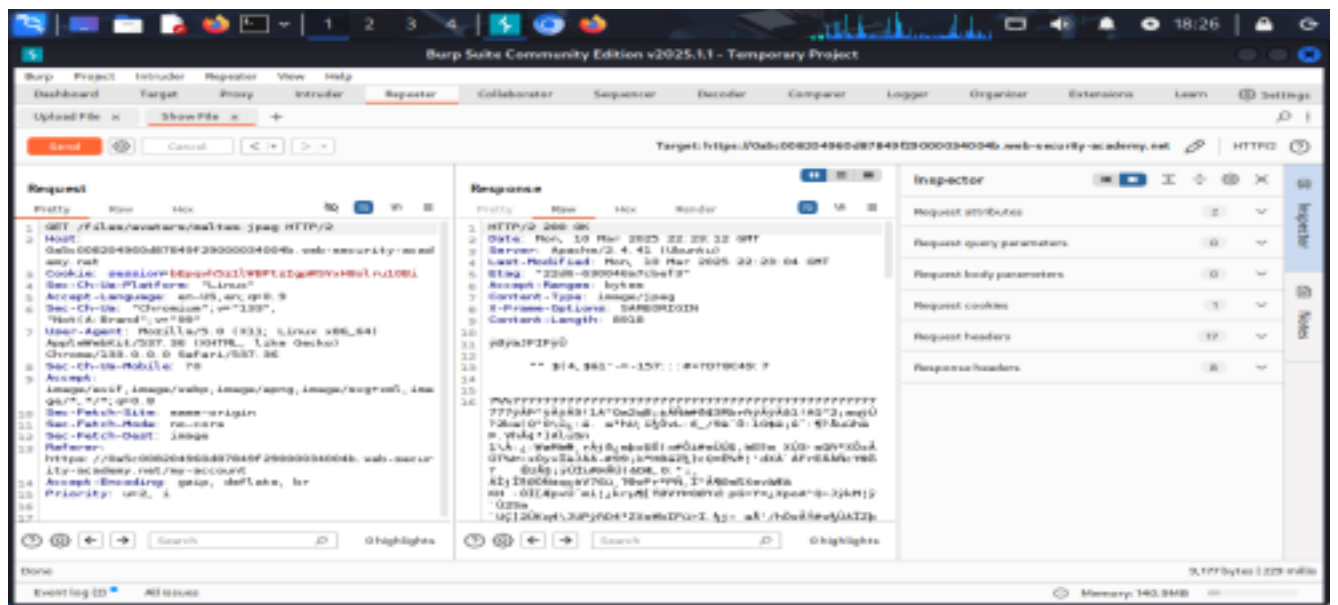
Images.



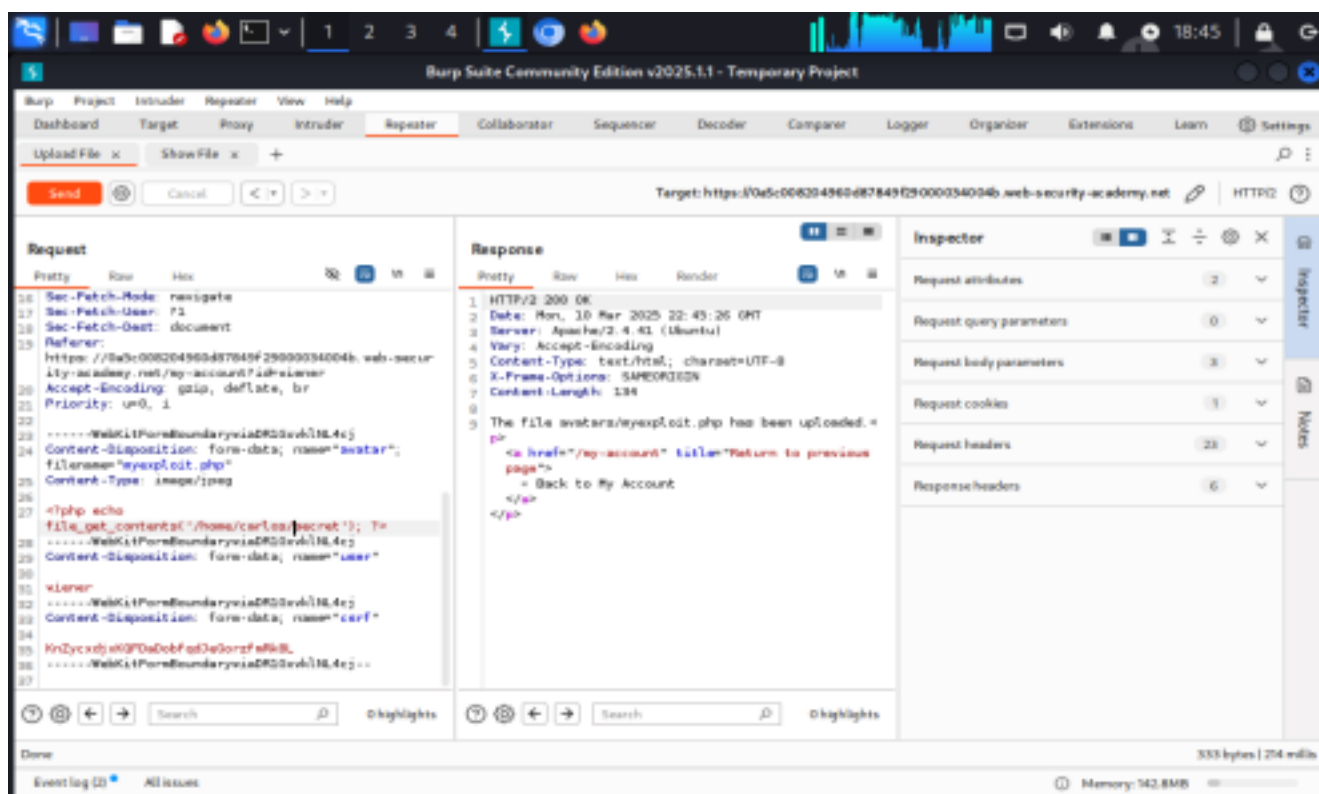
Passo 5 – Agora volte ao Burp Proxy HTTP History e localize o arquivo GET /files/avatars/maltes.jpg que é a foto que foi carregada, clicamos com o botão direito e selecionamos Send To Repeater, depois clicamos no Repeater e renomeamos a aba 1 para Upload File e na aba 2 Show File.



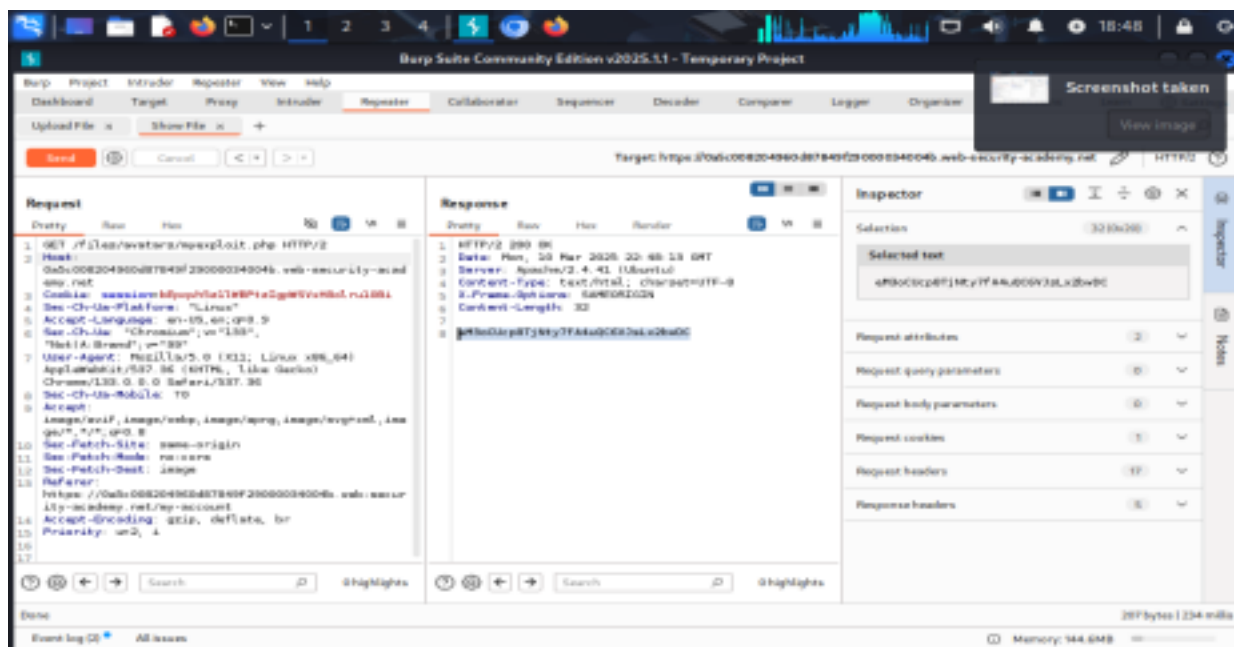
Passo 6 – Em Show File e Upload File clique em Send e os dois reponses serão 200 OK.



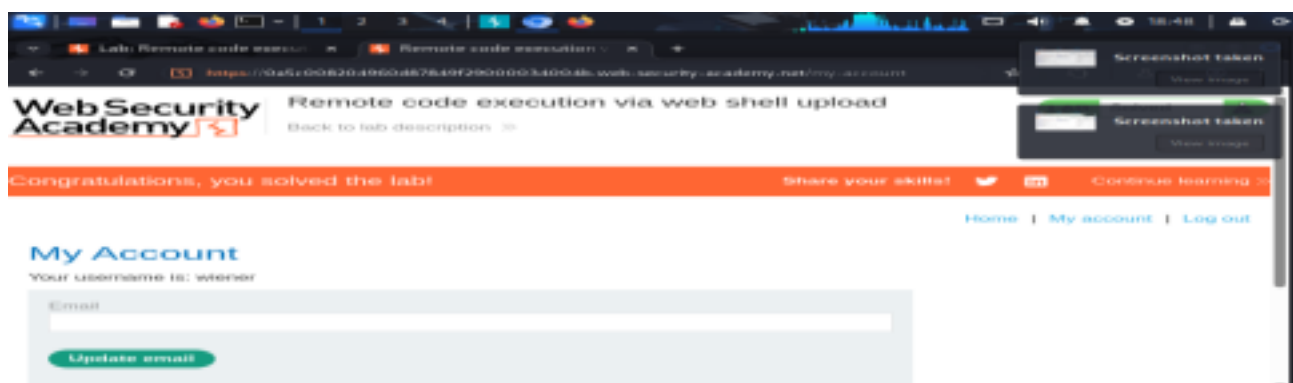
Passo 7 – No Upload Files apague toda a parte vermelha da figura e insira o código PHP `<?php echo file_get_contents('home/carlos/secret'); ?>` e clique em Send, aparecerá o código 200 OK



Passo 8 – Em Show File clique em Send e aparecerá o código para resolver o laboratório, copie este código

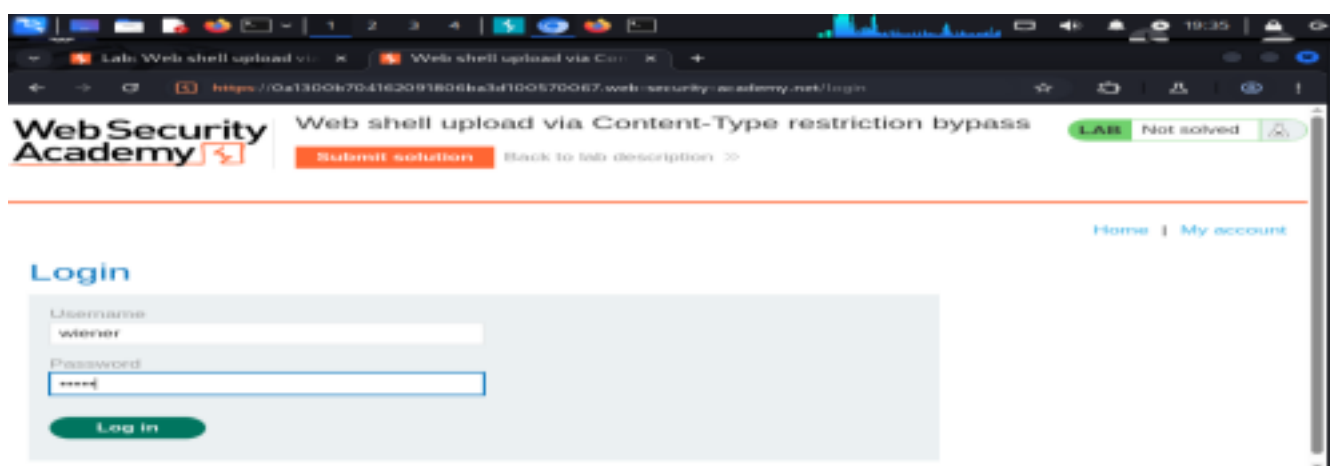


Passo 9 – Volte na página da internet, clique em Submit Solution, coloque o código que copiou OK e terá solucionado o laboratório.

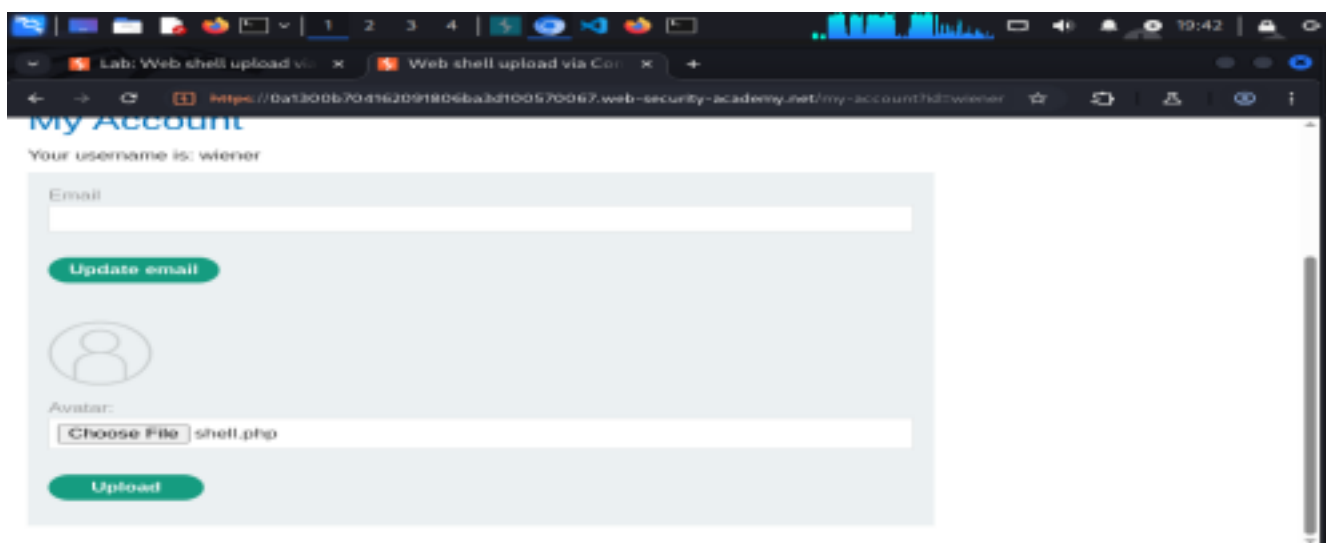


2.3. Atividade 2 – Upload do shell da Web por meio de bypass de restrição de tipo de conteúdo.

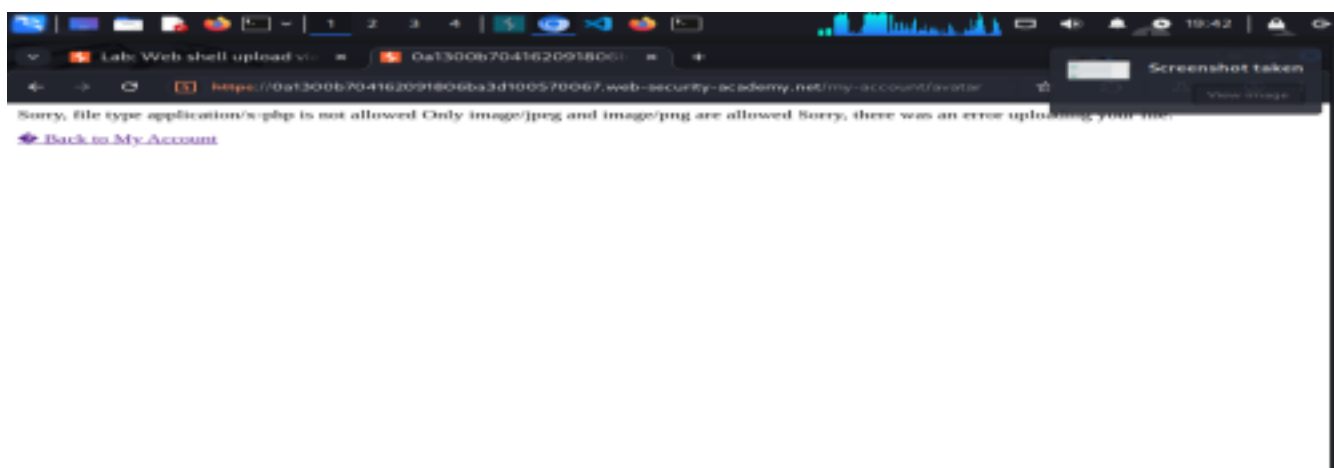
Passo 1 – Na página inicial clique em My account e entre com o usuário wiener e na senha peter, clique em login.



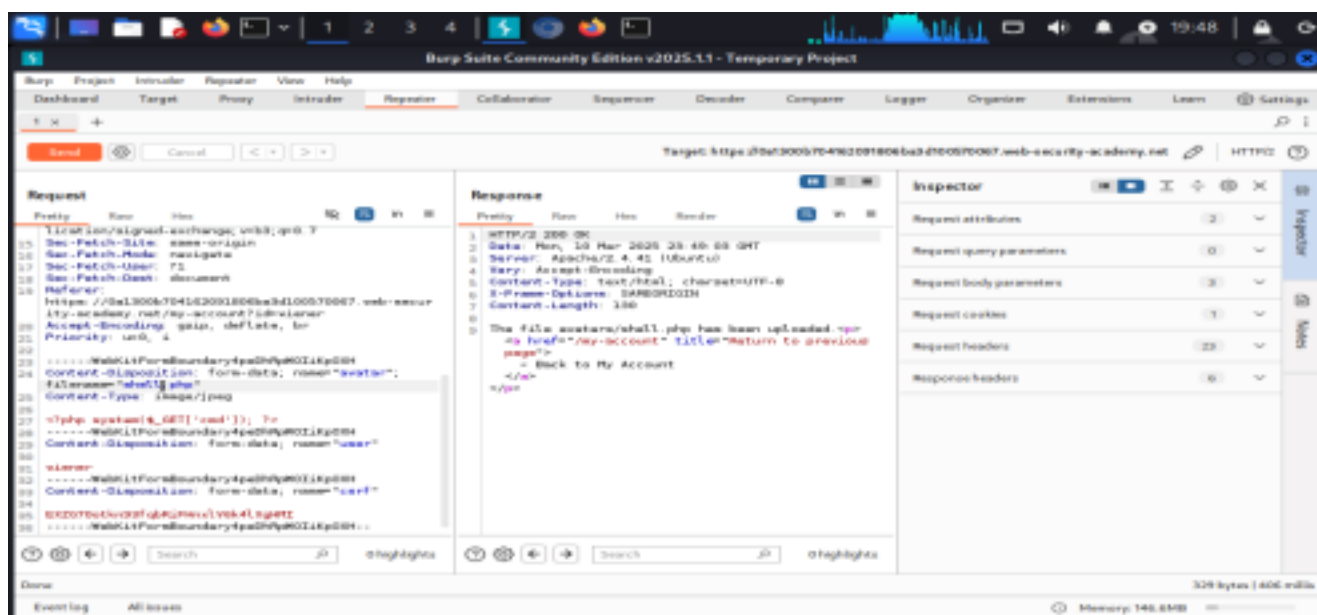
Passo 2 – Escrever um código PHP em um arquivo chamado shell.php com o seguinte comando `<?php system($_GET['cmd']); ?>`, na página inicial clique em Choose File e escolha o arquivo shell.php



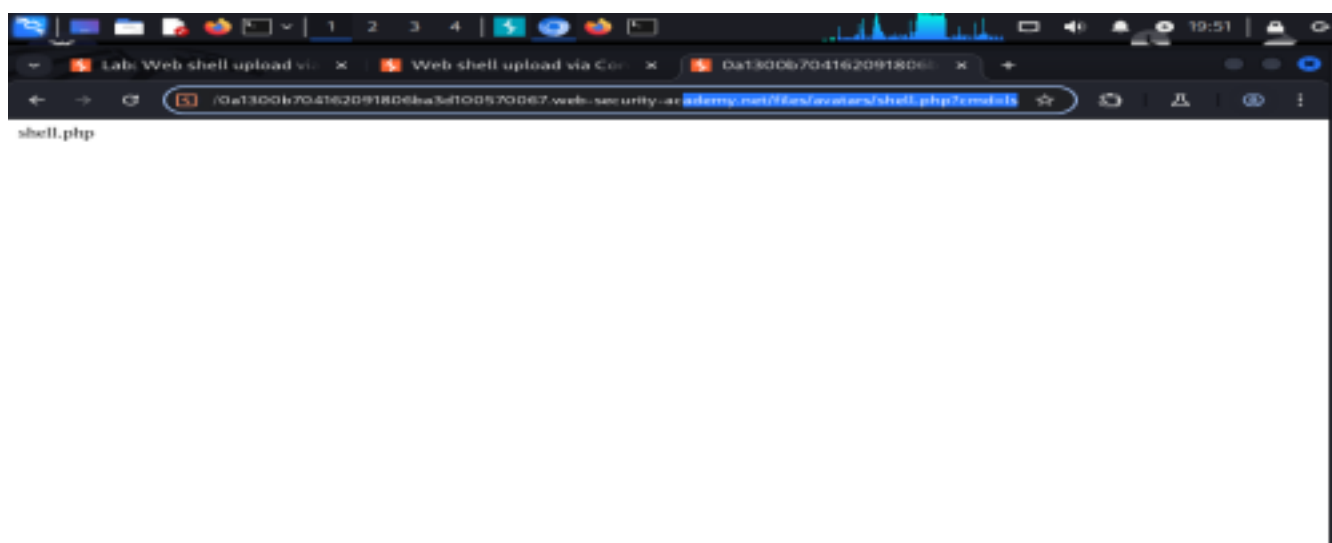
Passo 3 - Quando clicar em Upload irá informar que não aceita este tipo de arquivo php e clique em Back to My Account.



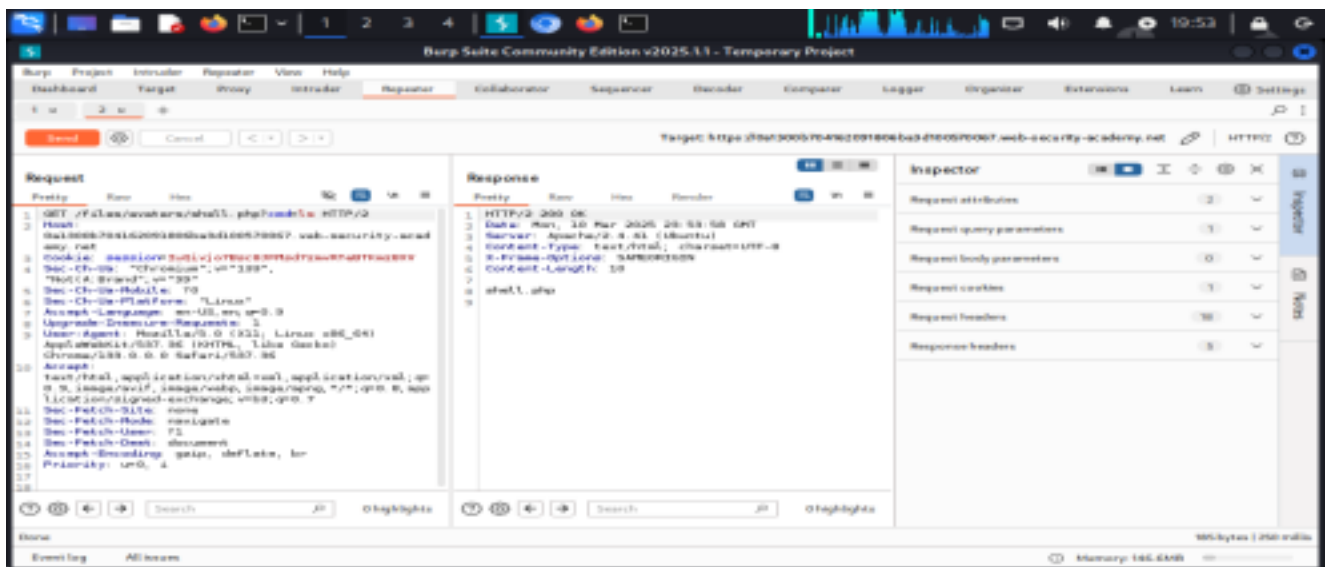
Passo 4 – No Burp em Proxy HTTP History localize o POST com o código /my-account/avatar clique com o botão direito e selecione Send To Repeater, no Repeater delete toda a parte vermelha que corresponde ao arquivo php e troque o filename para shell.php e clique em Send no Response receberá o código 200 OK.



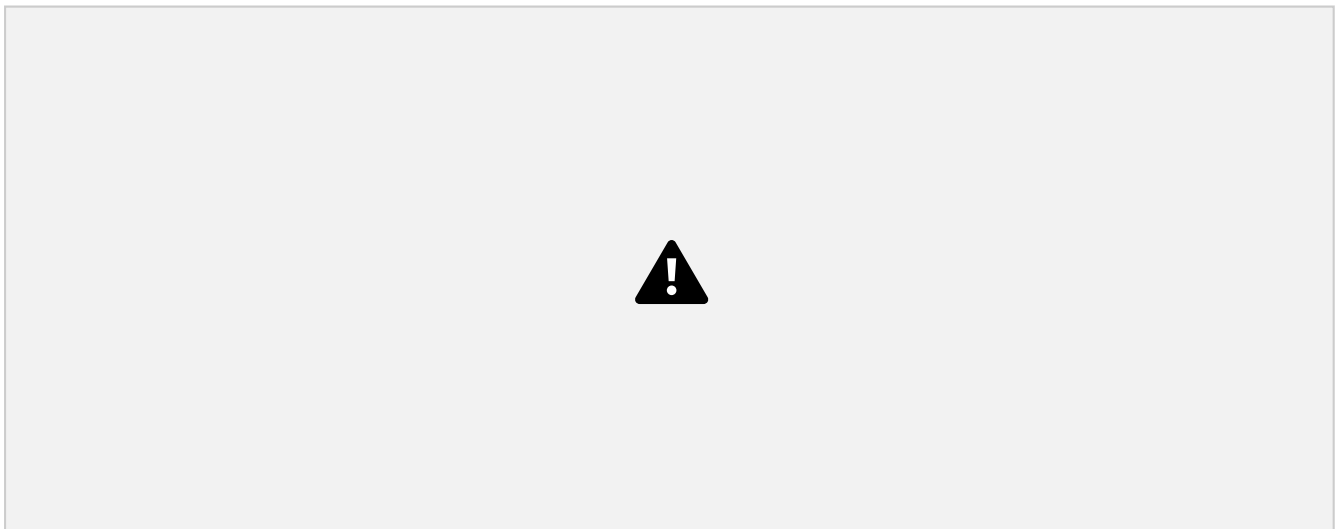
Passo 5 – Volte a página da internet e verá que o ícone da imagem estará quebrado, Clique no ícone de imagem com o botão direito, abrir nova imagem em uma nova guia no final da URL adicione ?cmd=ls e aparecerá na sua página web o arquivo shell.php



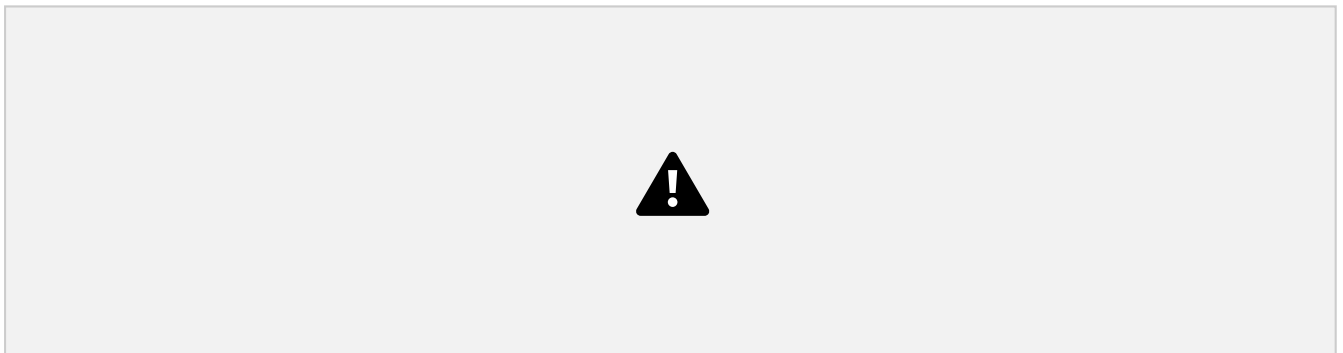
Passo 6 – Vamos no Burp em Proxy, HTTPHistory localizar o comando GET /files/avatars/shell.php?cmd=ls e clique em Send To Repeater, no Repeater adicionar no GET depois de php ?cmd=ls e clicar em Send vai aparecer o código 200 OK e escrito shell.php igual apareceu na página da internet.



Passo 7 – Novamente no get substitua depois do php pelo seguinte código cat+/home/carlos/secret e clique em Send, no Response aparecerá o código de resolução do laboratório.



Passo 8 – Volte na página de internet, clique em Submit Solution e o laboratório está concluído.



10

2.4. Atividade 3 - Upload de shell da Web por meio de desvio de lista negra de extensão.

Passo 1 – Na página inicial clique em My account e entre no usuário com wiener e na senha com peter, clique em login



Passo 2 – Clique em Choose File e escolha uma imagem com a extensão png, clicamos em Upload informa que a imagem e depois em Back My Account e aparecerá a figura que fez o upload.



Passo 3 –Agora vamos ao Burp Proxy/HTTPHistory clique em POST /myaccount/avatar clique com o botão direito e Send To Repeater, no Repeater apague toda a parte vermelha que corresponde a imagem, modificamos o filename para shell.php e o Content-Type para image/png e criamos um shell para tentar encontrar o secret de carlos, através do comando `<?php echo file_get_contents('/home/carlos/secret'); ?>` e clicamos em enviar e aparece o código 403 Forbidden Proibido e informa que os arquivos PHP não são permitidos e ele utiliza um servidor Apache 2.4.41.



Passo 4 – No Repeater substitua o filename por `.htaccess`, e modificar o Content-Type para o `text/plain` e vamos apagar o comando `php` e substituir por `AddType application/x-httpd-php-shell` e depois clique em Send e teremos o código 200 OK e informa que o arquivo `.htaccess` foi carregado no servidor.



12

Passo 5 – Volte na seta de voltar e modifique o filename para `shell.shell` e clicamos em enviar, informa que o arquivo `shell.shell` foi carregado.



Passo 6 – Voltamos a página da internet e atualizamos e vemos que ele não será exibido como imagem, vamos ao Burp Proxy/HTTPHistory em GET /files/avatars/shell.shell, clicamos nele e aparece o código secreto de carlos.



13

Passo 7 - Volte na página do exercício, clique em Submit Solution, coloque o código que copiou e OK e terá solucionado o laboratório.



2.5. Atividade 4 - Upload do shell da Web por meio de extensão de arquivo ofuscada.

Passo 1 - Na página inicial clique em My account e entre no usuário com wiener e na senha com peter, clique em login.



Passo 2 – Na página da internet clique em choose file e inclua o arquivo shell.php e informa que JPG e PNG apenas são autorizados, depois clique em Back My to Account.



Passo 3 – Depois vá no Burp Proxy/HTTPHistory procure por POST /my-account/avatar e clique em Send To Repeater, no repeater clique em send e mostrará o código 403 Forbidden, na parte de baixo em Request o código do nosso arquivo shell.php, tentamos mudar para pHp e não conseguimos continua dando código 403 Forbidden.



Passo 4 – No Request substitua o filename para shell.php.jpg e terá o código 200 OK



Passo 5 – Agora volte na página da internet clique com o botão direito do mouse e abrir a imagem em uma guia, depois volte no Burp e modifique o filename=”shell.php%00.jpg”



Passo 6 – Na aba no final da URL depois de php coloque o seguinte código cat/home/carlos/secret e aparecerá o código secreto de carlos.



Passo 7 - Volte na página do exercício, clique em Submit Solution, coloque o código que copiou e OK e terá solucionado o laboratório.



2.6. Análise dos Resultados:

Foi realizada a instalação do Burp Community no Kali Linux

Interpretação dos resultados:

- 1) Na Atividade 1 - Execução remota de código via upload de shell da web: Este site tem uma configuração insegura quando faz o upload do arquivo avatar, foi realizado o upload de um arquivo maltes.jpg, modificamos este arquivo para myexploit.php com o código `<?php echo file_get_contents('home/carlos/secret');` ? alteramos no Upload File e no Show File de maltes.jpg para myexploit.php mesmo mudando o tipo de arquivo ele continua aceitando pois não tem a validação e conseguimos acessar o arquivo secreto do usuário carlos mesmo sem estar logado com as credenciais dele;

- 2) Na Atividade 2 - Upload do shell da Web por meio de bypass de restrição de tipo de conteúdo:

Este site possui uma configuração que não aceita um arquivo colocado diretamente a não ser as extensões jpg ou png, criamos o arquivo shell.php, vamos no BURP e alteramos o content type para image/jpeg e conseguimos fazer o upload abrimos a imagem em outra aba, adicionamos ?cmd=ls, voltamos no Burp e substituímos o GET por cmd=cat+/home/carlos/secret e temos acesso ao arquivo secreto do carlos.

- 3) Na Atividade 3 - Upload de shell da Web por meio de desvio de lista negra de extensão: Foi realizado um upload de um arquivo png com sucesso, no Repeater vamos modificar o filename para shell.php e um comando para conseguir acesso ao arquivo do carlos mas aparece código 403 proibido, informa que arquivos php não são permitidos, mas informa que utiliza servidor apache, utilizamos o htaccess e adicionamos o comando AddType application/x-httpd-php .shell, o arquivo foi carregado com sucesso, depois voltamos e renomeamos o arquivo para shell.shell, vamos no Burp em files/avatar/shell.shell e conseguimos o código do usuário carlos.
- 4) Na Atividade 4 - Upload do shell da Web por meio de extensão de arquivo ofuscada: Tentamos fazer um upload do shell.php mas não é possível porque aceita apenas arquivos jpeg ou png, o arquivo é apenas para chamar o cmd do Windows, podemos colocar mais uma extensão no arquivo shell.php.jpg e podemos encodar o código para shell.php%00.jpg e conseguimos através do browser fazer comando para ter acesso ao código do carlos
?cmd=/home/carlos/secret.

2.7. Mitigação:

1. No laboratório 1 Execução remota de código via upload de shell da web: Fazer com que o site valide o tipo de arquivo e impeça scripts maliciosos.
2. No laboratório 2 Upload do shell da Web por meio de bypass de restrição de tipo de conteúdo: Mesmo com o controle de tipo de conteúdo, temos que utilizar uma White list em vez de black list ou seja, só permitir aquilo que é necessário e negar o restante por padrão;
3. No laboratório 3 Upload de shell da Web por meio de desvio de lista negra de extensão: não mostrar qual servidor web utiliza e a sua versão, através disso pode pesquisar vulnerabilidades e deixar a sua aplicação exposta à diversos tipos de ataque.
4. No laboratório 4 Upload do shell da Web por meio de extensão de arquivo ofuscada: Não autorizar arquivos com duas extensões como arquivo.php.jpg ou autorizar números e caracteres especiais depois da extensão como %00 exemplo arquivophp%00 .
5. Utilizar sempre listas brancas(white lists), que o arquivo não contenha nenhuma substring que possa ser interpretada como um diretório ou uma sequência de travessia (../), renomear os arquivos para evitar a substituição dele, não carregar arquivos até que sejam totalmente validados, use uma estrutura estabelecida para pré-processar uploads de arquivos em vez de tentar escrever seus próprios mecanismos de validação.

3. Considerações finais

Nesta sala, exploramos técnicas Pentest em Aplicações Web com o software Burp Suite Community para manipular algumas requisições, utilizando o Repeater para enviar requisições automaticamente,

apagar dados que não são necessários, alterar URLs para ter acesso a arquivos, colocar alguns comandos para enganar a lista negra como %00, modificar o tipo de arquivo para imagem, utilizar vulnerabilidades de servidor web.

As principais lições aprendidas incluem:

- 1) O upload do arquivo tem que ser controlado para que não se modifique o tipo de arquivo e consiga subir scripts maliciosos ou arquivos muito grandes que podem ocupar todo o espaço em disco do servidor.
- 2) Depois que o upload foi realizado não deixar modificar o campo Content-Type para um arquivo de imagem por exemplo, mesmo o arquivo carregado for com a extensão php e no Content Type for colocado image/jpg ou png ele irá aceitar e executar o script php dentro do servidor, basta abrir a imagem (que na verdade é um arquivo php) no browser e realizar os comandos dentro da URL ou no Burp, sempre fazer a validação entre o nome e o tipo de arquivo.
- 3) Cuidado ao deixar no seu banner o tipo e a versão de servidor que está utilizando, depois da solicitação de upload ser feita não deixar ser modificada pois podemos utilizar o Burp e o htaccess para manipular o servidor Apache por exemplo.
- 4) Na validação dos arquivos verificar se tem case sensitive pois podemos mudar uma letra e ele não reconhecer, tipo pHp em vez php, arquivos como arquivo.php.jpg ele pode validar apenas a última extensão do arquivo e quando salvar no servidor pode colocar apenas como arquivo.php deixando vulnerável a scripts maliciosos, pode utilizar codificação de URL ou codificação dupla de URL para ignorar os tipos de arquivos aceitos, podemos colocar apenas no final do arquivo para passar pela validação, pode também utilizar alguns caracteres Unicode multibyte que depois serão decodificados para bytes nulos ou pontos, analise remover ou substituir extensões de arquivos perigosos, pode procurar .php na string e remove-lo deixando o restante do arquivo, remover o comando curl para evitar estas brechas.
- 5) O que é File Upload? Ocorre quando os servidores da web carreguem arquivos sem fazer as validações necessárias como nome, tipo, conteúdo ou tamanho, fazendo com que se possa subir arquivos maliciosos inclusive com scripts que possam ser executados remotamente.

4. Referências

Site: <https://portswigger.net/web-security/file-upload/lab-file-upload-remote-code-execution-via-web-shell-upload>

Site: <https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-content-type-restriction-bypass>

Site: <https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-extension-blacklist-bypass>

Site: <https://portswigger.net/web-security/file-upload/lab-file-upload-web-shell-upload-via-obfuscated-file-extension>

